

The JUNIOR AI GOVERNANCE ANALYST HANDBOOK



**POLICIES
& STANDARDS**



**ETHICS
& RESPONSIBLE AI**



**RISK
MANAGEMENT**



**MONITORING
& ASSURANCE**



**CONTROLS
& SAFEGUARDS**



**DOCUMENTATION
& EVIDENCE**



**COMPLIANCE
& REGULATIONS**



**REAL-WORLD
PRACTICE**



@VERIQTA



@VERIQTA



VERIQTA



VERIQTA



VERIQTA



@VERIQTA

WHAT IS AI GOVERNANCE?

AI governance is the set of **policies, processes, roles, controls and oversight** used to ensure that AI systems are developed, deployed and used in a **responsible, safe, ethical and legally compliant** way.

WHY DO ORGANISATIONS NEED IT?

- AI can create real risks for people, data, business and society.
- It helps ensure AI is used ethically and responsibly.
- It builds trust with customers, regulators and the public.
- It reduces legal, reputational and financial risks.
- It ensures AI aligns with business goals and values.



DATA
Collects and uses data



AI MODEL
Learns patterns and makes predictions



OUTPUT
Produces content, decisions or recommendations

WITHOUT GOVERNANCE

- ❗ Biased or unfair decisions
- ❗ Privacy violations and data leaks
- ❗ Harmful or inaccurate outputs
- ❗ Misuse by malicious actors
- ❗ Legal and regulatory penalties
- ❗ Loss of customer trust
- ❗ Damage to brand reputation

WITH GOOD AI GOVERNANCE



SAFE
AI SYSTEMS



FAIR
OUTCOMES



REGULATORY
COMPLIANCE



TRUST
AND ADOPTION



BUSINESS
VALUE

KEY AREAS OF AI GOVERNANCE



Policies and standards
Set rules for responsible AI use.



Roles and accountability
Define who is responsible for what.



Risk management
Identify, assess and reduce AI risks.



Data governance
Ensure data is accurate, fair and secure.



Monitoring and oversight
Check performance and detect issues.



Compliance and legal requirements
Meet industry and regulatory rules.

REAL-WORLD EXAMPLE



A bank uses an AI system to assess loan applications. With governance, the bank checks for bias, ensures fair decisions and keeps records for regulatory review.



JUNIOR ANALYST TIP

AI governance is not about stopping innovation. It is about making sure AI is used in a way that is safe, fair, transparent and aligned with organisational and regulatory expectations.



@VERIQTA



@VERIQTA



VERIQTA



VERIQTA



VERIQTA



@VERIQTA

WHAT IS AN AI SYSTEM?

An AI system is a technology that uses **data**, **algorithms** and **computing power** to perform tasks that normally require human intelligence, such as understanding, learning, reasoning, analysing or creating content.

BASIC CONCEPT



DATA
Input data
(text, images,
voice, numbers)



AI MODEL
Learns patterns
from data



OUTPUT
Prediction,
decision or
new content

ARTIFICIAL INTELLIGENCE (AI)



The broad field of building systems that can perform tasks that require human intelligence.

Examples:

- Chatbots
- Recommendation systems
- Self-driving cars
- Fraud detection

MACHINE LEARNING (ML)



A subset of AI that learns patterns from data without being explicitly programmed.

Examples:

- Email spam detection
- Credit risk scoring
- Customer churn prediction
- Image classification

GENERATIVE AI



AI that can create new content such as text, images, audio, video and code based on what it has learned from data.

Examples:

- ChatGPT
- DALL·E
- Midjourney
- AI code assistants

LARGE LANGUAGE MODELS (LLM)



A type of generative AI trained on massive amounts of text to understand and generate human-like language.

Examples:

- OpenAI GPT
- Google Gemini
- Anthropic Claude
- Meta Llama

REAL-WORLD EXAMPLES



VIRTUAL ASSISTANTS

ChatGPT, Gemini, Alexa
(answer questions, automate tasks)



RECOMMENDATION SYSTEMS

Netflix, Amazon
(suggest products or content)



FRAUD DETECTION

Banks
(detect unusual transactions)



AUTONOMOUS VEHICLES

Tesla
(understand environment and make decisions)



HEALTHCARE

AI models
(analyse medical images for early detection)



IMPORTANT TO KNOW

- An AI system is not just ChatGPT.
- AI systems can be more than chatbots.
- Many AI systems work behind the scenes in everyday applications.
- They can be used in business, healthcare, finance, education, manufacturing and more.

COMMON MISUNDERSTANDINGS

- ! All AI is ChatGPT. (Incorrect)
- ! ChatGPT is the only AI tool. (Incorrect)
- ! AI always thinks like a human. (Incorrect)
- ! AI systems are always accurate. (Incorrect)
- ! AI systems do not have risks. (Incorrect)



WHO IS A JUNIOR AI GOVERNANCE ANALYST?



A junior AI governance analyst helps organisations use AI responsibly by supporting **governance**, **risk management**, **compliance** and **monitoring** activities across the AI lifecycle.

DAILY RESPONSIBILITIES



- Support AI risk assessments
- Review AI policies and controls
- Collect and organise evidence
- Maintain AI inventories and records
- Monitor AI systems for issues
- Assist with compliance and regulatory checks
- Work with technical and business teams
- Prepare reports and document findings

REQUIRED SKILLS



Understanding of AI technologies and their risks



Knowledge of governance, risk and compliance concepts



Analytical and critical thinking



Good communication skills



Comfort working with technical teams



Attention to detail



Problem-solving skills



Willingness to learn and stay updated on AI regulations and best practices

KEY STAKEHOLDERS



Business Teams

Use AI solutions in the organisation



AI Developers and Engineers

Build and maintain AI systems



Risk and Compliance Teams

Ensure regulatory and internal compliance



Management and Executives

Provide direction and make decisions



Legal Team

Advise on legal and regulatory requirements



Data Teams

Provide and manage data used in AI systems



Internal or External Auditors

Review controls and evidence



End Users / Customers

Interact with AI systems

KEY DELIVERABLES



AI risk assessment reports



AI inventory and documentation



Review of AI policies and standards



Control recommendations



Monitoring and incident reports



Compliance and regulatory evidence



Presentations and status updates

REPORTING RELATIONSHIP



Planning, data collection, development, testing, deployment, monitoring and retirement

WHAT IS THE AI SYSTEM LIFECYCLE?

The AI system lifecycle is the **end-to-end journey** an AI system goes through, from initial **planning to final retirement**. Each stage has different activities, risks and governance requirements.



WHY IT MATTERS

- Helps manage risks at each stage
- Ensures responsible and ethical use
- Improves transparency and accountability
- Supports compliance and regulatory needs



1. PLANNING

- Define the problem and business goals
- Identify stakeholders
- Assess legal, ethical and regulatory requirements
- Evaluate risks and feasibility



Output:

- Project plan
- Governance requirements



2. DATA COLLECTION

- Identify and source data
- Check data quality
- Ensure data is lawful, ethical and representative
- Protect sensitive information



Output:

- Data collection plan
- Prepared and approved datasets



3. DEVELOPMENT

- Select the right AI/ML approach
- Train and tune the model
- Apply security and privacy controls
- Document development process



Output:

- Trained model
- Development documentation



4. TESTING

- Test accuracy and performance
- Check for bias and fairness
- Validate security and robustness
- Ensure compliance with policies and regulations



Output:

- Test results
- Risk and bias assessment reports



5. DEPLOYMENT

- Deploy the model to production
- Set up access controls
- Monitor initial performance
- Ensure user communication and training



Output:

- Deployed AI system
- Operational runbook



6. MONITORING

- Track performance and accuracy
- Detect model drift
- Monitor for harmful or unexpected outputs
- Respond to incidents
- Review compliance and control effectiveness



Output:

- Monitoring reports
- Incident records



7. RETIREMENT

- Determine when the system is no longer needed
- Securely decommission the model, data and infrastructure
- Archive key documentation
- Ensure regulatory and legal requirements are met



Output:

- Decommissioned system
- Archived records

KEY GOVERNANCE CHECKPOINTS



- Ethical and responsible use
- Risk assessments
- Regulatory compliance
- Data protection and privacy
- Human oversight
- Documentation and audit trails
- Ongoing monitoring and review

REAL-WORLD EXAMPLE



A company builds an AI chatbot for customer support.

- 1 Plan the use case and assess risks
- 2 Collect and prepare customer data
- 3 Develop and train the model
- 4 Test for accuracy, bias and safety
- 5 Deploy to production
- 6 Monitor for harmful or incorrect outputs
- 7 Retire the model when it is no longer needed



@VERIQTA



@VERIQTA



VERIQTA



VERIQTA



VERIQTA



@VERIQTA

Fairness, transparency, accountability, privacy, safety, security and human oversight

WHAT ARE RESPONSIBLE AI PRINCIPLES?

Responsible AI principles are a set of guidelines that help ensure AI systems are developed and used in a way that is **fair**, **transparent**, **safe**, **secure**, **accountable** and **aligned with human values** and societal good.

WHY THEY MATTER



Reduce harm to people and society



Build trust in AI systems



Support legal and regulatory compliance



Improve long-term sustainability



Ensure AI aligns with organisational values



1. FAIRNESS

AI systems should treat people fairly and avoid unjust bias or discrimination.

Key practices:

- Use diverse and representative data
- Test for bias
- Monitor for unfair outcomes



2. TRANSPARENCY

AI systems should be understandable, with clear information about how they work and their limitations.

Key practices:

- Explain how the model works
- Document data and methods
- Be clear about limitations



3. ACCOUNTABILITY

There should be clear ownership and responsibility for AI systems and their outcomes.

Key practices:

- Define roles and responsibilities
- Maintain audit trails
- Ensure oversight and governance



4. PRIVACY

AI systems should protect personal data and respect people's privacy.

Key practices:

- Minimise data collection
- Use data securely
- Comply with privacy laws such as GDPR



5. SAFETY

AI systems should be safe and reliable, reducing the risk of harm to people, property or the environment.

Key practices:

- Test for harmful outputs
- Validate before deployment
- Monitor for unexpected behaviour



6. SECURITY

AI systems should be protected against misuse, attacks and unauthorised access.

Key practices:

- Secure data and models
- Control access
- Monitor for threats and misuse



7. HUMAN OVERSIGHT

Humans should remain in control, especially for high-risk or high-impact decisions.

Key practices:

- Keep a human in the loop
- Allow for human review and intervention
- Set clear escalation processes



REAL-WORLD EXAMPLES



Healthcare AI

Ensure fair and accurate diagnosis, with human review.



Financial AI

Prevent biased lending decisions and detect fraud.



HR AI

Use AI for recruitment with fairness tests and human oversight.



@VERIQTA



@VERIQTA



VERIQTA



VERIQTA



VERIQTA



@VERIQTA

The four functions: GOVERN, MAP, MEASURE and MANAGE, with practical examples.

WHAT IS NIST AI RMF?



The NIST AI Risk Management Framework (AI RMF) provides guidance to help organisations manage risks and build trustworthy AI systems. It is structured around four core functions: **GOVERN**, **MAP**, **MEASURE** and **MANAGE**.

WHY USE NIST AI RMF?



Helps identify and manage AI risks



Supports trustworthy and responsible AI



Can be used across different industries



Improves transparency and accountability



Complements existing standards and regulations



1. GOVERN

Establish and oversee the policies, processes and accountability for AI risk management.

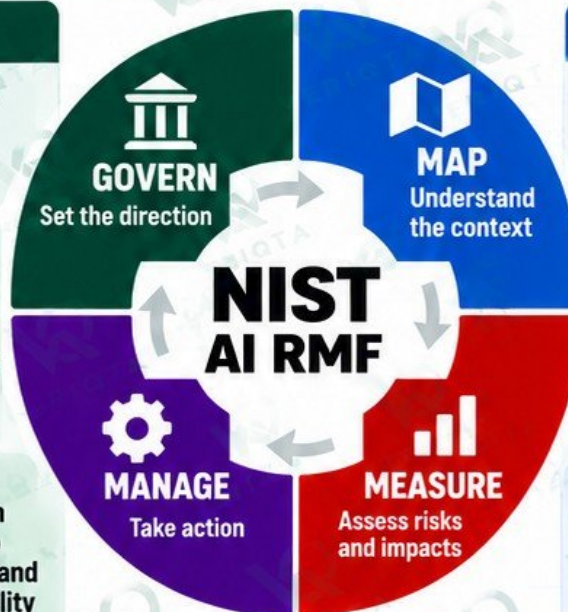
Key activities:

- Set AI governance policies
- Define roles and responsibilities
- Establish risk appetite
- Ensure legal and ethical compliance
- Engage stakeholders



Practical example:

A company creates an AI policy, defines who approves AI projects and sets clear accountability for AI risks.



2. MAP

Understand the context, identify the AI system and its risks, and map the ecosystem.

Key activities:

- Understand the use case
- Identify stakeholders
- Map the AI system lifecycle
- Identify risks and dependencies
- Consider the broader impact on people and society



Practical example:

A bank maps its AI loan approval system, including data sources, users, third-party providers and potential risks such as bias and privacy.



3. MEASURE

Assess, analyse and evaluate AI risks and potential impacts.

Key activities:

- Assess likelihood and impact of risks
- Use qualitative and quantitative methods
- Evaluate fairness, bias, privacy, security and safety
- Measure performance and effectiveness of controls



Practical example:

A company tests its AI recruitment tool for biased results, checks model accuracy and evaluates the potential impact on candidates.



4. MANAGE

Take action to manage AI risks and improve trust over time.

Key activities:

- Implement risk treatment plans
- Monitor AI systems in production
- Respond to incidents and unexpected behaviour
- Continuously improve based on feedback and new risks
- Communicate with stakeholders



Practical example:

A healthcare provider sets up monitoring for harmful outputs in its AI chatbot, responds to user reports and updates the model based on findings.



KEY TAKEAWAY

NIST AI RMF helps organisations build, use and manage AI systems in a way that is fair, safe, secure and aligned with human values.



REAL-WORLD BENEFITS

- Reduces risks and harmful impacts
- Builds trust with users and regulators
- Supports innovation with responsible AI
- Helps meet legal and industry requirements



@VERIQTA



@VERIQTA



VERIQTA



VERIQTA



VERIQTA



@VERIQTA

Understanding an AI Management System, governance policies, organisational responsibilities and continual improvement.

WHAT IS ISO/IEC 42001?



ISO/IEC 42001 is an international standard for establishing, implementing, maintaining and continually improving an **AI Management System (AIMS)** in organisations.

KEY OBJECTIVES



- Provide a structured approach to manage AI risks
- Ensure responsible and trustworthy AI use
- Align AI with organisational goals and legal requirements
- Improve transparency and accountability
- Support continual improvement

WHO CAN USE IT?



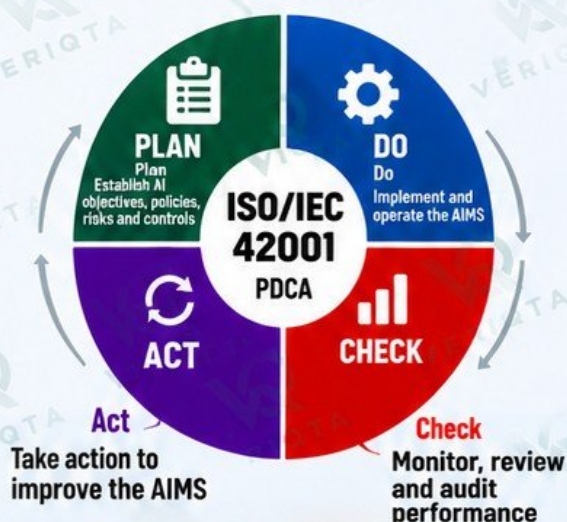
Any organisation that develops, provides or uses AI systems, regardless of size, industry or type of AI technology.



HOW IT WORKS

ISO/IEC 42001 follows the Plan-Do-Check-Act (PDCA) cycle, helping organisations build and continually improve their AIMS.

PDCA CYCLE IN ISO/IEC 42001



KEY ELEMENTS OF THE STANDARD

1		Context of the Organisation	Understand internal and external factors that affect AI.
2		Leadership	Top management commitment and clear direction.
3		Planning	Identify risks and opportunities, set AI objectives.
4		Support	Provide resources, competence, awareness and communication.
5		Operation	Implement and control AI processes.
6		Performance Evaluation	Monitor, measure, analyse and audit.
7		Improvement	Take action to address issues and continually improve the AIMS.



GOVERNANCE POLICIES

- Define how AI is used and managed
- Set ethical and responsible AI principles
- Align with legal and regulatory requirements
- Establish roles, approvals and oversight
- Include data governance, security and privacy policies



ORGANISATIONAL RESPONSIBILITIES

- Top management provides oversight and support
- Define roles and responsibilities for AI governance
- Assign an AI management system owner
- Ensure teams have the right skills and training
- Involve legal, risk, compliance and IT teams



CONTINUAL IMPROVEMENT

- Regularly monitor AI performance and risks
- Use audit results and stakeholder feedback
- Address incidents and non-conformities
- Update policies, controls and processes
- Adapt to new technologies, regulations and business needs



REAL-WORLD EXAMPLE

A healthcare organisation implements ISO/IEC 42001 to govern its AI diagnostic tool by defining policies, assessing risks, training staff, monitoring model performance and regularly reviewing and improving its AI management system.



@VERIQTA



@VERIQTA



VERIQTA



VERIQTA



VERIQTA



@VERIQTA

Risk-based regulation, prohibited practices, high-risk systems, transparency obligations and applicability.

WHAT IS THE EU AI ACT?



The EU AI Act is the world's first comprehensive law to regulate AI. It sets rules for the development, placement on the market and use of AI systems based on a **risk-based approach**.

KEY OBJECTIVES



- Protect people's fundamental rights and safety
- Ensure trustworthy and human-centric AI
- Promote transparency and accountability
- Support innovation and responsible AI development
- Create a harmonised regulatory framework across the EU

RISK-BASED APPROACH



The EU AI Act classifies AI systems into different risk levels, with stricter rules for higher-risk systems.



PROHIBITED PRACTICES (UNACCEPTABLE RISK)

The following AI practices are banned in the EU:

- Manipulating people's behaviour in a way that causes harm
- Exploiting vulnerabilities of children or vulnerable groups
- Social scoring by public authorities
- Real-time remote biometric identification in public spaces (with limited exceptions)
- Using AI for predictive policing based only on profiling



HIGH-RISK AI SYSTEMS

High-risk AI systems are subject to strict requirements before they can be placed on the market or used.

Examples include:

- AI used in critical infrastructure
- Education and vocational training
- Employment, worker management and access to self-employment
- Access to essential private and public services (e.g. banking)
- Law enforcement, migration and border control
- Administration of justice and democratic processes
- Medical devices and healthcare



TRANSPARENCY OBLIGATIONS

Certain AI systems must be transparent so that users understand they are interacting with AI.

This includes:

- Informing users when they are interacting with an AI system (e.g. chatbots)
- Clearly labelling AI-generated content (text, images, audio, video)
- Providing information about the capabilities and limitations of the AI system
- Ensuring transparency for deepfakes and synthetic media



WHO DOES IT APPLY TO?

The EU AI Act applies to:

- Providers (developers) of AI systems
- Deployers (organisations that use AI systems)
- Importers and distributors
- Service providers
- Organisations inside and outside the EU if the AI system is placed on the EU market or used in the EU



KEY COMPLIANCE REQUIREMENTS

- Risk management and governance
- High-quality data and data management
- Technical documentation
- Transparency and user information
- Human oversight
- Accuracy, robustness and cybersecurity
- Conformity assessment for high-risk systems
- Ongoing monitoring and incident reporting



KEY TAKEAWAY

The EU AI Act sets clear rules to ensure AI systems are safe, transparent, accountable and respect fundamental rights, using a risk-based approach with strict requirements for high-risk systems.



REAL-WORLD EXAMPLE



A company developing an AI recruitment tool for use in the EU must comply with the high-risk requirements, including risk assessment, data quality, transparency, human oversight and ongoing monitoring.



@VERIQTA



@VERIQTA



VERIQTA



VERIQTA



VERIQTA



@VERIQTA

Governance, legal compliance, risk management, internal controls and audit.
Understanding their differences.

WHAT IS AI GOVERNANCE?



AI governance is the overall framework of policies, processes and oversight used to ensure AI systems are developed, deployed and used **responsibly, ethically** and in line with organisational goals and values.

WHAT IS AI COMPLIANCE?



AI compliance means meeting the **legal, regulatory and industry requirements** that apply to AI systems. It focuses on following the rules, laws and standards set by external authorities such as the EU AI Act, ISO/IEC 42001 and other relevant regulations.



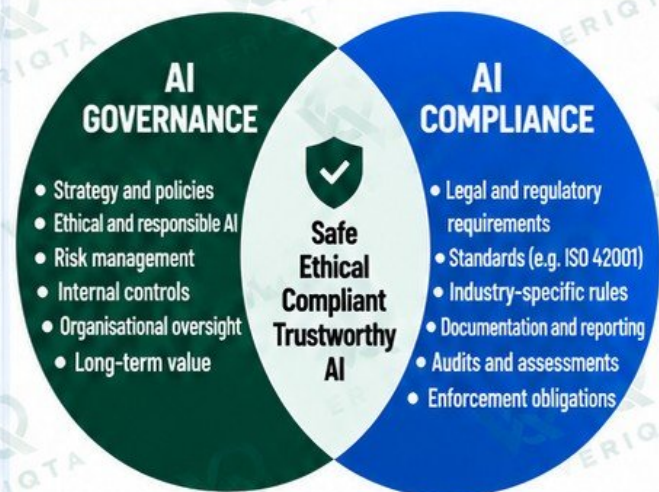
KEY DIFFERENCES

ASPECT	AI GOVERNANCE	AI COMPLIANCE
 Focus	Broader strategic oversight and responsible use of AI	Meeting specific legal and regulatory requirements
 Scope	Covers entire AI lifecycle, ethics, risk, accountability and value	Covers applicable laws, regulations and standards
 Driver	Organisational values, business goals and stakeholder expectations	External legal and regulatory obligations
 Nature	Proactive and strategic	Reactive and rule-based
 Outcome	Responsible, trustworthy and well-managed AI	Demonstrable adherence to laws and standards
 Accountability	Shared across leadership, management and all stakeholders	Specific to roles responsible for regulatory adherence and reporting



HOW THEY WORK TOGETHER

AI governance and AI compliance are **complementary**. Governance sets the direction and overall framework, while compliance ensures that the organisation meets its legal and regulatory obligations within that framework.



EXAMPLES

AI GOVERNANCE EXAMPLES

- Setting AI principles and policies
- Establishing an AI risk management framework
- Defining roles and responsibilities
- Approving high-risk AI use cases
- Ongoing monitoring and oversight

AI COMPLIANCE EXAMPLES

- Complying with the EU AI Act
- Implementing ISO/IEC 42001 requirements
- Meeting data protection laws (GDPR)
- Completing regulatory reports
- Preparing for external audits



KEY TAKEAWAYS

- ✓ AI governance is about doing the right thing.
- ✓ AI compliance is about following the rules.
- ✓ Governance reduces risk and builds trust.
- ✓ Compliance ensures legal and regulatory adherence.
- ✓ Both are essential for responsible and sustainable AI.



@VERIQTA



@VERIQTA



VERIQTA



VERIQTA



VERIQTA



@VERIQTA

AI owners, developers, deployers, compliance teams, risk owners, auditors and management responsibilities.



AI OWNERS

Responsible for the overall AI system, its use and business outcomes.

Key responsibilities:

- Set the vision and objectives
- Ensure responsible and ethical use
- Approve use cases and funding
- Maintain accountability
- Monitor value and risks



AI DEVELOPERS

Design, build and test the AI system.

Key responsibilities:

- Develop models and applications
- Use quality and representative data
- Follow security and privacy practices
- Test for bias, fairness and performance
- Document design and limitations



AI DEPLOYERS

Deploy AI systems into production and ensure they operate safely.

Key responsibilities:

- Prepare the infrastructure
- Ensure security and access controls
- Monitor system performance
- Manage changes and updates
- Respond to incidents



COMPLIANCE TEAMS

Ensure the organisation meets legal, regulatory and policy requirements.

Key responsibilities:

- Monitor compliance with laws and standards (e.g. EU AI Act, ISO/IEC 42001)
- Review policies and procedures
- Advise on regulatory changes
- Ensure proper documentation
- Support audits and assessments



RISK OWNERS

Identify, assess and manage AI risks.

Key responsibilities:

- Identify and evaluate risks
- Define and implement risk treatment plans
- Monitor emerging risks
- Work with technical and business teams
- Report significant risks to management



AUDITORS

Provide independent assurance on AI systems and controls.

Key responsibilities:

- Evaluate compliance and controls
- Assess risk management practices
- Review documentation and evidence
- Identify gaps and improvement areas
- Report findings to management and relevant stakeholders



MANAGEMENT / LEADERSHIP

Provide oversight, direction and accountability for AI across the organisation.

Key responsibilities:

- Set the overall strategy and risk appetite
- Ensure adequate resources and skills
- Approve policies and governance frameworks
- Monitor performance, risks and compliance
- Hold teams accountable for responsible AI use



HOW THEY WORK TOGETHER

All roles work together throughout the AI lifecycle to ensure AI systems are safe, compliant, reliable and aligned with organisational goals.

Key activities:

- Clear roles and responsibilities
- Regular communication and collaboration
- Shared policies, standards and controls
- Continuous monitoring and improvement
- Escalation of issues and risks



KEY TAKEAWAYS

- ✓ AI governance requires clear roles and accountability.
- ✓ Every role has specific responsibilities at different stages of the AI lifecycle.
- ✓ Collaboration between technical, compliance, risk, audit and management teams is essential.
- ✓ Clear accountability helps reduce risk, ensure compliance and build trust in AI systems.



@VERIQTA



@VERIQTA



VERIQTA



VERIQTA



VERIQTA



@VERIQTA

Bias, hallucinations, privacy exposure, data leakage, model misuse, security threats and operational failures.



1. BIAS

AI systems can produce unfair or discriminatory outputs due to biased data, design or use.

Examples:

- Biased hiring recommendations
- Discriminatory loan approvals
- Unequal treatment in healthcare
- Underrepresentation in training data



2. HALLUCINATIONS

AI models can generate incorrect or made-up information that looks convincing but is false.

Examples:

- Fake references or citations
- Incorrect facts or statistics
- Non-existent policies or laws
- Confident but wrong answers



3. PRIVACY EXPOSURE

AI systems can expose personal or sensitive information, intentionally or accidentally.

Examples:

- Leaking customer data in responses
- Exposing PII from training data
- Re-identification of anonymised data
- Unauthorised access to sensitive data



4. DATA LEAKAGE

Sensitive data can be leaked through model inputs, outputs, logs or third-party services.

Examples:

- Confidential data in prompts
- Sensitive data in model outputs
- Training data leaked from the model
- Data shared with external AI providers



5. MODEL MISUSE

AI models can be intentionally misused for harmful, illegal or unethical activities.

Examples:

- Generating malware or phishing content
- Creating deepfakes or misinformation
- Automating fraud or social engineering
- Using AI for prohibited or high-risk purposes



6. SECURITY THREATS

AI systems can be targeted by adversaries, leading to attacks, manipulation or unauthorised access.

Examples:

- Prompt injection attacks
- Model stealing or data extraction
- Adversarial inputs to manipulate outputs
- Unauthorised access to AI infrastructure



7. OPERATIONAL FAILURES

AI systems can fail due to technical issues, poor design, lack of monitoring or unexpected behaviour.

Examples:

- System downtime or service disruption
- Incorrect or inconsistent model outputs
- Inadequate monitoring and alerting
- Dependency failures (APIs, cloud services, data sources)



RISK MITIGATION STRATEGIES

- Use high-quality and representative data
- Implement strong data governance and access controls
- Test for bias, fairness and robustness
- Monitor model performance and behaviour
- Apply security controls and threat detection
- Set clear acceptable use policies
- Conduct regular audits and risk assessments
- Have incident response and rollback plans



KEY TAKEAWAY

AI brings many benefits, but it also introduces real risks. Identifying and managing these risks is essential to ensure AI systems are safe, reliable, ethical and aligned with organisational goals and legal requirements.



REAL-WORLD EXAMPLE

A company using an AI chatbot experienced data leakage when employees accidentally entered confidential customer information. This highlights the importance of data governance, access controls and employee training.



Likelihood, impact, inherent risk, existing controls, residual risk and risk ratings.



1. LIKELIHOOD

The probability that a risk event will occur.

- Rare – May occur in exceptional circumstances
- Unlikely – Could occur at some time
- Possible – Might occur at some time
- Likely – Will probably occur
- Almost Certain – Expected to occur frequently



2. IMPACT

The potential consequence or harm if the risk event occurs.

- Insignificant – Minimal effect
- Minor – Limited impact
- Moderate – Noticeable impact
- Major – Significant impact
- Severe – Critical impact (legal, financial, safety, reputation)



3. INHERENT RISK

The level of risk before any controls are applied.

- Calculated using likelihood and impact
- Shows the natural level of risk
- Helps prioritise risks for treatment



4. EXISTING CONTROLS

Policies, processes and technical measures that reduce the likelihood or impact of a risk.

- Preventive controls – Stop the risk from occurring
- Detective controls – Identify the risk early
- Corrective controls – Reduce the impact when it occurs
- Examples: access controls, monitoring, data protection, model testing, human oversight



5. RESIDUAL RISK

The remaining level of risk after existing controls are applied.

- Lower than or equal to the inherent risk
- Used to decide if the risk is acceptable
- May require additional controls if still high



6. RISK RATINGS

A way to categorise and communicate the level of risk.

- Typically: Low, Medium, High, Critical
- Based on the residual risk score
- Helps with prioritisation, reporting and decision-making



RISK ASSESSMENT PROCESS



RISK RATING MATRIX (EXAMPLE)

IMPACT	Severe	5	Medium	High	High	Critical	Critical
	Major	4	Medium	Medium	High	High	Critical
	Moderate	3	Low	Medium	Medium	High	High
	Minor	2	Low	Low	Medium	Medium	High
	Insignificant	1	Low	Low	Low	Medium	Medium
			1 Rare	2 Unlikely	3 Possible	4 Likely	5 Almost Certain
		LIKELIHOOD					



EXAMPLE: AI CHATBOT RISK ASSESSMENT

Risk	Likelihood (1-5)	Impact (1-5)	Inherent Risk	Existing Controls	Residual Risk	Rating
Biased outputs	4	4	High	Model testing, content filters, human review	Medium	Medium
Data leakage	3	5	High	Access controls, encryption, monitoring	Medium	Medium
Hallucinations (misinformation)	4	3	High	Prompt guardrails, validation, user warnings	Medium	Medium
Model misuse (harmful content)	3	4	High	Usage policies, monitoring, human oversight	Low	Low



KEY TAKEAWAYS

- Assess both likelihood and impact for each risk.
- Understand the difference between inherent and residual risk.
- Apply appropriate controls to reduce risk.
- Use consistent risk ratings to prioritise and communicate.
- Regularly review and update risks and controls.



COMMON AI RISKS TO ASSESS

- Bias and unfair outcomes
- Hallucinations and misinformation
- Privacy exposure and data leakage
- Model misuse and harmful content
- Security threats (e.g. prompt injection)
- Operational failures and downtime
- Regulatory and legal non-compliance
- Reputational and ethical risks



@VERIQTA



@VERIQTA



VERIQTA



VERIQTA



VERIQTA



@VERIQTA

System ID, risk description, category, owner, impact, likelihood, controls, treatment and review status.

WHAT IS AN AI RISK REGISTER?



An AI risk register is a central record of all identified AI risks, their assessment, controls and treatment plans. It helps track, manage and monitor risks throughout the AI lifecycle.

WHY IT IS IMPORTANT



- Provides a clear view of AI risks
- Supports informed decision-making
- Helps meet legal and regulatory requirements
- Improves accountability and oversight
- Ensures risks are regularly reviewed and updated

KEY BENEFITS



- Better risk visibility
- Improved control and governance
- Supports compliance and audits
- Reduces potential harm and losses
- Promotes responsible and trustworthy AI



KEY FIELDS IN AN AI RISK REGISTER

ID	RISK DESCRIPTION	CATEGORY	OWNER	IMPACT	LIKELIHOOD	CONTROLS	TREATMENT	REVIEW STATUS
								
Unique identifier for each risk.	Clear and concise description of the risk.	Type of risk (e.g. bias, privacy, security, operational).	Person or team responsible for managing the risk.	Potential consequence if the risk occurs.	Probability of the risk occurring.	Existing controls to reduce the risk.	Planned actions to address the risk (e.g. mitigate, avoid, transfer, accept).	Current status (e.g. open, in progress, closed) and next review date.



EXAMPLE AI RISK REGISTER

ID	RISK DESCRIPTION	CATEGORY	OWNER	IMPACT	LIKELIHOOD	EXISTING CONTROLS	TREATMENT	REVIEW STATUS
AI-001	Biased outputs in recruitment tool	Bias / Fairness	HR Team	High	Likely	Bias testing, human review	Mitigate	In Progress
AI-002	Exposure of personal data in AI responses	Privacy	Data Protection Team	High	Possible	Data masking, access controls	Mitigate	Open
AI-003	Hallucinated or incorrect information	Model Risk	Product Team	Medium	Likely	Human review, prompt guidelines	Mitigate	In Progress
AI-004	Malicious prompt injection attacks	Security	Security Team	High	Possible	Input filtering, threat detection	Mitigate	Open
AI-005	Model misuse for harmful content	Misuse / Ethics	Compliance Team	High	Unlikely	Usage policy, monitoring, reporting	Prevent	Under Review
AI-006	Service downtime affecting AI system	Operational	IT / Operations	Medium	Possible	Monitoring, backup and recovery	Mitigate	Open



BEST PRACTICES

- Use clear and consistent categories
- Assign accountable owners
- Be realistic with impact and likelihood
- Document existing controls and gaps
- Define and track treatment actions
- Review and update regularly
- Integrate with governance, compliance and audit processes



KEY TAKEAWAYS

- An AI risk register helps you systematically identify, assess and manage AI risks.
- It provides a clear structure with key fields such as ID, category, owner, impact, likelihood, controls, treatment and review status.
- Regular updates and review ensure risks are monitored, controls remain effective and responsible AI use is maintained.



@VERIQTA



@VERIQTA



VERIQTA



VERIQTA



VERIQTA



@VERIQTA

Access control, data protection, human review, testing, approval gates, logging and incident escalation.



1. ACCESS CONTROL

Control who can access AI systems, data and model capabilities.

- Use role-based access control (RBAC)
- Follow the principle of least privilege
- Restrict access to sensitive data and models
- Use multi-factor authentication (MFA)
- Regularly review and remove unnecessary access



2. DATA PROTECTION

Protect sensitive and personal data used in AI systems.

- Classify and label data (e.g. public, internal, confidential)
- Use encryption for data at rest and in transit
- Apply data minimisation (use only what is needed)
- Remove or anonymise personally identifiable information (PII)
- Follow data retention and deletion policies



3. HUMAN REVIEW

Ensure appropriate human oversight and review.

- Use human review for high-risk or sensitive use cases
- Define clear review responsibilities
- Provide reviewers with guidelines and checklists
- Escalate uncertain or harmful outputs
- Maintain a record of human decisions



4. TESTING

Test AI systems to identify risks and ensure reliability.

- Test for bias, fairness and accuracy
- Evaluate security and robustness
- Use red teaming and adversarial testing
- Test with real-world and edge cases
- Verify model performance before and after deployment



5. APPROVAL GATES

Use formal approval gates before deployment and major changes.

- Define clear approval criteria
- Require risk and compliance review
- Ensure testing results meet acceptable thresholds
- Involve relevant stakeholders (technical, legal, risk)
- Document and track all approvals



6. LOGGING AND MONITORING

Record and monitor AI system activity for accountability and security.

- Log user interactions, model inputs and outputs
- Monitor for unusual or suspicious activity
- Track changes to models and configurations
- Set up alerts for potential abuse or policy violations
- Ensure logs are retained and protected



7. INCIDENT ESCALATION

Have a clear process to escalate and respond to AI incidents.

- Define what is considered an AI incident (e.g. harmful output, data leak, security breach)
- Set up escalation channels and contacts
- Establish response procedures and timelines
- Conduct root cause analysis and implement fixes
- Document lessons learned and prevent recurrence



KEY TAKEAWAYS

- ✓ A combination of technical, organisational and procedural controls is needed to manage AI risks.
- ✓ Controls should be implemented throughout the AI lifecycle.
- ✓ Regular monitoring, review and improvement are essential.
- ✓ Clear accountability and incident escalation help ensure safe and responsible AI use.



COMMON CONTROLS SUMMARY

- ✓ Access control (RBAC, MFA)
- ✓ Data protection (encryption, anonymisation)
- ✓ Human review and oversight
- ✓ Testing (bias, security, robustness)
- ✓ Approval gates and change control
- ✓ Logging and monitoring
- ✓ Incident escalation and response
- ✓ Regular review and improvement



@VERIQTA



@VERIQTA



VERIQTA



VERIQTA



VERIQTA



@VERIQTA

AI inventories, system cards, model cards, policies, assessment records, approvals and audit trails.



1. AI INVENTORIES

Maintain a central inventory of all AI systems and models used in the organisation.

- Unique ID and name
- Purpose and business use case
- Owner and responsible team
- Model type (LLM, CV, etc.)
- Deployment environment
- Risk classification
- Status (active, retired, in development)



2. SYSTEM CARDS

Provide a high-level overview of each AI system.

- System description
- Intended use and scope
- Key stakeholders
- Data inputs and outputs
- Dependencies and integrations
- Risk level and controls
- Contact information



3. MODEL CARDS

Document detailed information about each AI model.

- Model purpose and design
- Training data and sources
- Performance metrics
- Limitations and known risks
- Bias and fairness assessment
- Recommended use cases
- Monitoring and updates



4. POLICIES AND PROCEDURES

Define and document rules for the responsible use of AI.

- AI governance policy
- Acceptable use policy
- Data handling and privacy policy
- Security requirements
- Model development and deployment standards
- Roles and responsibilities
- Regular review and updates



5. ASSESSMENT RECORDS

Keep records of all risk, compliance and impact assessments.

- Risk assessments
- Bias and fairness assessments
- Privacy impact assessments
- Security assessments
- Legal and regulatory assessments
- Results, findings and recommendations
- Actions taken and follow-up



6. APPROVALS

Document and track all approvals before and after deployment.

- Design and development approvals
- Risk and compliance sign-off
- Legal and data protection approval
- Business owner approval
- Change management approvals
- Records of who approved and when
- Conditions and limitations



7. AUDIT TRAILS

Maintain logs and records of key activities for accountability.

- Model training and version history
- Data access and usage logs
- System changes and configuration updates
- User interactions (where required)
- Approval and review logs
- Incident and issue logs
- Retention period and access controls



8. DOCUMENTATION LIFECYCLE

Keep documentation up to date throughout the AI lifecycle.

- Create at design and development
- Update after changes or retraining
- Review on a regular basis
- Retain for audit and regulatory needs
- Use version control
- Archive old versions
- Ensure easy access for authorised teams



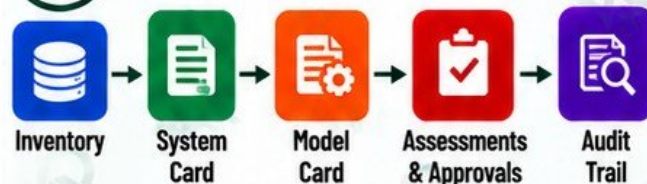
9. EVIDENCE FOR AUDITS

Be prepared to provide evidence to internal and external auditors.

- Complete and accurate records
- Policies and procedures
- Assessment reports
- Approval documents
- Logs and audit trails
- Evidence of control implementation
- Management review records



EXAMPLE DOCUMENTATION FLOW



KEY TAKEAWAYS

- ✓ Clear and consistent documentation builds trust and accountability.
- ✓ AI documentation supports governance, compliance and risk management.
- ✓ Keep records up to date and easily accessible.
- ✓ Well-documented evidence helps with audits and regulatory requirements.
- ✓ Use standard templates and maintain version history.
- ✓ Documentation is essential throughout the entire AI lifecycle.



@VERIQTA



@VERIQTA



VERIQTA



VERIQTA



VERIQTA



@VERIQTA

Assessing external AI vendors, contractual responsibilities, data handling, security and provider dependencies.



1. VENDOR DUE DILIGENCE

Assess the AI vendor before engagement to understand risks and capabilities.

- Review vendor background and reputation
- Assess AI capabilities and use cases
- Evaluate compliance and certifications
- Check financial stability and ownership
- Understand data sources and model training



2. CONTRACTUAL RESPONSIBILITIES

Define clear contractual terms to manage AI-related risks.

- Specify acceptable use of the AI service
- Define data ownership and usage rights
- Include security and privacy requirements
- Set liability and indemnification terms
- Require compliance with relevant regulations
- Include audit and termination rights



3. DATA HANDLING

Ensure your data is properly protected when shared with third-party AI providers.

- Identify what data is shared
- Classify data (public, internal, confidential)
- Verify data encryption in transit and at rest
- Understand data retention and deletion policies
- Prevent misuse of your data for model training (unless agreed)



4. SECURITY ASSESSMENT

Evaluate the vendor's security practices and controls.

- Review security certifications (e.g. ISO 27001, SOC 2)
- Assess infrastructure and access controls
- Check vulnerability and patch management
- Verify incident response and breach notification
- Ensure secure development and model deployment practices



5. PROVIDER DEPENDENCIES

Understand and manage dependencies on third-party AI providers.

- Identify critical AI services and functions
- Assess the impact of provider downtime
- Evaluate exit strategy and migration options
- Avoid over-reliance on a single provider
- Plan for business continuity and resilience



6. ONGOING MONITORING

Continuously monitor vendor performance and risks.

- Review service performance and SLA compliance
- Monitor for changes in model behaviour
- Track security incidents and regulatory updates
- Conduct regular risk reviews and assessments
- Reassess the vendor periodically



7. KEY RISK AREAS

Common risks when using third-party AI providers.

- Data privacy and confidentiality risks
- Security breaches and unauthorised access
- Model bias and unfair outcomes
- Lack of transparency and explainability
- Regulatory and legal non-compliance
- Service disruption and provider dependency



8. RISK MITIGATION STRATEGIES

Take proactive steps to reduce third-party AI risks.

- Conduct thorough due diligence
- Use strong contractual controls
- Implement data protection measures
- Monitor vendor performance and security
- Have a clear exit and transition plan
- Regularly review and update risk assessments



KEY TAKEAWAYS

- ✓ Third-party AI providers can bring significant benefits, but also introduce important risks.
- ✓ Always assess vendors, contracts, data handling, security and dependencies.
- ✓ Continuous monitoring and strong governance help ensure safe and responsible use of third-party AI.



COMMON THIRD-PARTY AI DOCUMENTS

- ✓ Vendor risk assessment questionnaire
- ✓ Contract and data processing agreement (DPA)
- ✓ Security and compliance certifications
- ✓ Service level agreement (SLA)
- ✓ Regular monitoring and review reports
- ✓ Incident response and breach notification terms
- ✓ Exit and transition plan



@VERIQTA



@VERIQTA



VERIQTA



VERIQTA



VERIQTA



@VERIQTA

Prompt injection, sensitive data exposure, unreliable outputs, acceptable use and human verification.

1. WHAT IS GENERATIVE AI?



Generative AI creates new content such as text, code, images and more based on user input.

- Examples: ChatGPT, Claude, Copilot, Gemini, open-source models
- Useful for productivity, automation and creativity
- Introduces unique risks that require governance and controls

2. PROMPT INJECTION



Attackers can manipulate prompts to make the AI ignore instructions or perform harmful actions.

- Override system instructions
- Extract sensitive information
- Bypass safety controls
- Generate harmful, biased or unauthorised content
- Use indirect or hidden prompts (e.g. in documents, links, images)

3. SENSITIVE DATA EXPOSURE



Users may unintentionally share confidential or personal information in prompts.

- Customer data, employee data and business information
- Source code, system configurations and internal documents
- Data may be stored or used for model training (depending on provider)
- Can lead to privacy, legal and reputational risks



4. UNRELIABLE OUTPUTS

Generative AI can produce incorrect, misleading or made-up information (hallucinations).

- Outputs may sound correct but be wrong
- Can include biased or inappropriate content
- May lack up-to-date or factual information
- Should not be used for critical decisions without verification
- Verify outputs with trusted sources and human review



5. ACCEPTABLE USE

Set clear rules for how generative AI tools can be used in the organisation.

- Define approved tools and use cases
- Prohibit sharing of sensitive or confidential data
- Specify what content is allowed and not allowed
- Follow legal, regulatory and ethical requirements
- Ensure users understand their responsibilities
- Provide training and awareness



6. HUMAN VERIFICATION

Keep humans in the loop for important decisions and high-risk use cases.

- Review and validate AI outputs
- Check for accuracy, bias and completeness
- Use human oversight for critical, legal, financial or safety-related content
- Define clear roles and approval processes
- Do not fully automate high-impact decisions



EXAMPLES OF GENERATIVE AI RISKS

Prompt Injection

Malicious prompt bypasses safety controls

Sensitive Data Exposure

Confidential data shared in prompts

Unreliable Outputs

Incorrect or misleading information

Bias and Inappropriate Content

Biased, harmful or offensive outputs

Policy Violation

Use outside acceptable use policies

Reputational and Legal Risk

Regulatory breaches and loss of trust



GOVERNANCE FRAMEWORK



KEY TAKEAWAYS

- ✓ Generative AI is powerful but comes with significant risks.
- ✓ Prompt injection, data exposure and unreliable outputs are key concerns.
- ✓ Clear policies, strong controls and human verification help ensure safe and responsible use.



COMMON CONTROLS AND SAFEGUARDS

- ✓ Use approved AI tools and secure configurations
- ✓ Apply data loss prevention (DLP) measures
- ✓ Sanitise prompts and inputs
- ✓ Limit access and use role-based controls
- ✓ Monitor usage and detect unusual activity
- ✓ Implement content filtering and safety controls
- ✓ Provide user training and guidance
- ✓ Require human review for high-risk outputs
- ✓ Regularly review and update policies
- ✓ Keep audit logs and evidence of AI usage



@VERIQTA



@VERIQTA



VERIQTA



VERIQTA



VERIQTA



@VERIQTA

Model drift, performance degradation, harmful outputs, monitoring indicators, escalation and incident records.

1. WHAT IS AI MONITORING?



AI monitoring is the continuous tracking of model behaviour, performance and risks to detect issues early.

- Track model performance
- Detect unusual or harmful outputs
- Monitor data and system changes
- Ensure compliance and safety
- Help maintain trust and reliability

2. KEY MONITORING INDICATORS



Monitor key indicators to identify potential issues with AI systems.

- Model accuracy and performance
- Response latency and error rates
- Data quality and drift
- Unusual or unexpected outputs
- User feedback and complaints
- Security and abuse indicators
- System and infrastructure health

3. MODEL DRIFT



Model drift happens when the model's performance degrades over time due to changes in data or environment.

- Changes in input data patterns
- Decreased accuracy or relevance
- Increase in incorrect or biased outputs
- Monitor data drift and concept drift
- Retrain or update the model when needed



4. PERFORMANCE DEGRADATION

Performance degradation occurs when the model no longer meets expected standards.

- Lower accuracy or quality of outputs
- Increased response time or failures
- Higher error rates
- Reduced user satisfaction
- Identify root cause and take corrective action



5. HARMFUL OUTPUTS

AI systems may generate harmful, biased or unsafe outputs if not properly monitored.

- Hate speech or offensive content
- Misinformation or misleading outputs
- Bias or discrimination
- Privacy violations or sensitive data leaks
- Content that violates organisational policies



6. INCIDENT DETECTION

Detect incidents early using monitoring tools and defined thresholds.

- Set alerts for abnormal behaviour
- Use logging and real-time monitoring
- Detect security incidents and abuse
- Monitor user reports and feedback
- Define clear incident criteria
- Automate detection where possible



7. ESCALATION PROCESS

Have a clear escalation process for AI incidents.

- Define severity levels (low, medium, high)
- Identify who to escalate to
- Set response time targets
- Involve legal, compliance and security teams
- Communicate with stakeholders
- Take immediate steps to reduce harm



8. INCIDENT RECORDS

Maintain detailed records of all AI incidents for learning, compliance and audit purposes.

- Date and time of incident
- Description of what happened
- Impact and affected systems
- Root cause analysis
- Actions taken and resolution
- Lessons learned and follow-up actions
- Keep records for regulatory and audit requirements



EXAMPLE AI INCIDENT FLOW



KEY TAKEAWAYS

- ✓ Continuous monitoring helps detect issues early.
- ✓ Monitor for model drift, performance degradation and harmful outputs.
- ✓ Have clear escalation and incident response processes.
- ✓ Keep detailed incident records for compliance and learning.
- ✓ Regularly review and improve monitoring and response.



@VERIQTA



@VERIQTA



VERIQTA



VERIQTA



VERIQTA



@VERIQTA

A practical workflow for reviewing an organisation's proposed AI chatbot before deployment.

1

UNDERSTAND THE PROPOSAL

Review the purpose, scope and intended use of the AI chatbot.



- What problem will it solve?
- Who will use it?
- What are the key features?
- Where will it be deployed?
- What business value is expected?

2

IDENTIFY STAKEHOLDERS

Engage the right people early in the review.



- Business owner and product team
- IT and security teams
- Legal and compliance
- Data protection and privacy team
- End users and customer support

3

REVIEW DATA USAGE

Assess what data will be used, stored and shared.



- Types of data (public, internal, confidential, sensitive)
- Data sources and collection methods
- Data retention and deletion policies
- Use of personal or sensitive data
- Data sharing with third parties

4

ASSESS RISKS

Identify and evaluate key risks associated with the chatbot.



- Bias and unfair outputs
- Hallucinations and misinformation
- Privacy and data leakage
- Security threats and abuse
- Reputational and legal risks
- Impact on customers and employees

5

REVIEW CONTROLS

Check if appropriate controls and safeguards are in place.



- Access control and user authentication
- Content filtering and safety controls
- Human review for critical outputs
- Logging and monitoring
- Incident response plan
- Compliance with legal and regulatory requirements

6

TEST AND VALIDATE

Evaluate the chatbot before deployment.



- Test for accuracy and reliability
- Check for bias and harmful outputs
- Evaluate privacy and security controls
- Run real-world and edge case scenarios
- Validate against organisational policies
- Document test results and issues

7

MAKE A DECISION

Determine if the chatbot is ready for deployment.

- Approve, approve with conditions or reject
- Ensure all critical risks are addressed
- Confirm required controls are implemented
- Document the decision and rationale
- Communicate the outcome to stakeholders

8

PREPARE FOR DEPLOYMENT

Ensure ongoing governance after approval.



- Set monitoring and review schedule
- Define ownership and responsibilities
- Establish incident escalation process
- Provide user guidance and training
- Plan for continuous improvement
- Keep records for audit and compliance

9

MONITOR AND REVIEW

Track performance and address issues after deployment.



- Monitor key indicators (accuracy, user feedback, incidents)
- Review logs and incident records
- Assess changes in risk over time
- Update controls and policies as needed
- Conduct regular governance reviews



KEY CHECKLIST

- ✓ Purpose and scope clearly defined
- ✓ Risks identified and assessed
- ✓ Appropriate controls in place
- ✓ Testing completed with acceptable results
- ✓ All approvals obtained
- ✓ Monitoring and incident response ready
- ✓ Documentation complete



WORKFLOW SUMMARY



Review Proposal Engage Stakeholders Assess Risks Check Controls Test and Validate Approve and Deploy Monitor and Review



KEY TAKEAWAYS

- ✓ A structured review helps ensure safe and responsible use.
- ✓ Involve the right stakeholders from the start.
- ✓ Focus on data, risks, controls and testing.
- ✓ Make a clear decision and keep records.
- ✓ Continuous monitoring and review are essential.



@VERIQTA



@VERIQTA



VERIQTA



VERIQTA



VERIQTA



@VERIQTA

Complete a miniature governance assessment, identify risks, recommend controls, document evidence and prepare a review summary.

1

SCENARIO OVERVIEW



You are a junior analyst in the Governance, Risk and Compliance team. Your organisation wants to deploy an AI chatbot to help customers with product support.

Your task:

- Review the proposal
- Identify key risks
- Recommend controls
- Document your findings
- Prepare a review summary

2

UNDERSTAND THE AI CHATBOT



Gather key information about the proposed chatbot.

- Purpose and use case
- Target users
- Type of AI model (e.g. LLM)
- Data sources and integrations
- Where it will be deployed (web, mobile)
- Intended business value
- Owner and responsible teams

3

IDENTIFY RISKS



Analyse the proposal and identify potential risks.

- Inaccurate or misleading outputs
- Bias or unfair responses
- Exposure of sensitive data
- Data leakage to third parties
- Prompt injection and misuse
- Security vulnerabilities
- Regulatory and legal risks
- Reputational and customer trust risks
- Operational and business continuity risks

4

ASSESS AND PRIORITISE RISKS



Evaluate the identified risks based on likelihood and impact.

- Use a simple risk rating (Low, Medium, High)
- Consider the impact on customers, organisation and regulators
- Focus on the most significant risks
- Document your risk assessment in a clear table
- Highlight high-risk areas that require immediate attention

5

RECOMMEND CONTROLS



Propose practical controls to reduce or manage the risks.

- Technical controls (e.g. input filtering)
- Data protection controls
- Access control and user authentication
- Human review for high-risk responses
- Clear acceptable use policy
- Monitoring and logging
- Incident response plan
- Regular testing and model evaluation

6

DOCUMENT EVIDENCE



Prepare and organise evidence to support your assessment.

- AI system and data inventory
- Risk assessment table
- Proposed controls and policies
- Screenshots or diagrams (if available)
- Records of stakeholder discussions
- Applicable regulatory requirements
- Approval and review checklist

7

PREPARE A REVIEW SUMMARY



Write a clear and concise summary for the decision makers.

- Overview of the chatbot and purpose
- Key risks identified
- Recommended controls
- Overall risk rating (e.g. Low / Medium / High)
- Readiness for deployment (Approve / Approve with conditions / Do not approve)
- Next steps and open items

8

SAMPLE RISK ASSESSMENT TABLE

Risk	Likelihood	Impact	Risk Rating	Recommended Control
Biased outputs	Medium	High	High	Human review and testing
Sensitive data exposure	Medium	High	High	Data masking and DLP
Inaccurate information	High	Medium	High	Improve prompt controls
Prompt injection	Medium	High	High	Input filtering and monitoring
Data leakage to third parties	Low	High	Medium	Restrict data sharing and use contracts



LAB DELIVERABLES



Risk Assessment Table



Recommended Controls



Evidence Documents



Review Summary



Final Recommendation



KEY TAKEAWAYS

- ✓ A structured assessment helps identify and manage AI risks.
- ✓ Practical controls reduce risk and support safe deployment.
- ✓ Clear documentation provides evidence for compliance.
- ✓ A concise review summary helps decision makers.
- ✓ This process can be applied to real-world AI projects.



@VERIQTA



@VERIQTA



VERIQTA



VERIQTA



VERIQTA



@VERIQTA